Отчёт о результатах тестирования на проникновение: Active Directory (GOAD Lab)

> Дата проведения: 24.10.2025 — 25.10.2025
> Модель теста: Grey-box
> Общая оценка защищённости: **Critical (критическая)**

Содержание

1. Executive Summary (Резюме для руководства)
2. Scope (Область тестирования)
3. Methodology (Методология и инструментарий)
4. Detailed Findings (Детальные результаты тестирования)
5. Conclusion & Strategic Roadmap (Заключение и выводы)
6. Appendices & References (Приложения и источники)

1. Executive Summary (Резюме для руководства)

В ходе учебного тестирования лаборатории Active Directory (GOAD) были обнаружены уязвимости, позволяющие получить права Domain Administrator — максимальный уровень доступа в Windows-сети.

Общая оценка защищённости: Critical (критическая)

Ключевые находки:

- Загрузка ASPX веб-шелла через форму файлов — High
- Повышение привилегий через SeImpersonatePrivilege — Critical
- Дамп учётных данных через mimikatz — Critical
- Kerberoasting и AS-REP Roasting — Medium
- WriteDACL на группу Domain Admins — Critical
- ESC1 через AD CS — Critical
- Подделка Golden Ticket — Critical
- Закрепление через Scheduled Task — High

№	Уязвимость	Затронутый узел / компонент	Критичность
1	Загрузка ASPX веб-шелла	CASTELBLACK (192.168.56.22)	**High**

№	Уязвимость	Затронутый узел / компонент	Критичность
2	SeImpersonatePrivilege → SYSTEM	CASTELBLACK (192.168.56.22)	**Critical**
3	Дамп LSASS/SAM через mimikatz	CASTELBLACK (192.168.56.22)	**Critical**
4	Kerberoasting	jon.snow	**Medium**
5	AS-REP Roasting	brandon.stark, missandei	**Medium**
6	WriteDACL на Domain Admins	WINTERFELL (192.168.56.11)	**Critical**
7	ESC1 через AD CS	MEEREEN (192.168.56.12)	**Critical**
8	Golden Ticket (подделка Kerberos-тикета)	KINGSLANDING (192.168.56.10)	**Critical**
9	Закрепление через Scheduled Task	KINGSLANDING (192.168.56.10)	**High**
10	WinRM Lateral Movement	BRAAVOS, MEEREEN, KINGSLANDING	**Medium**

Рекомендации (что делать в первую очередь):

- Убрать уязвимую форму загрузки файлов
- Ограничить SeImpersonatePrivilege у сервисных аккаунтов
- Исправить шаблоны сертификатов AD CS
- Убрать WriteDACL с критичных групп
- Сменить пароль krbtgt дважды

2. Scope (Область тестирования)

Что тестировалось:

- Сеть: 192.168.56.0/24
- Хосты: CASTELBLACK, WINTERFELL, MEEREEN, KINGSLANDING, BRAAVOS
- Сервисы: IIS, SMB, LDAP, Kerberos, WinRM, AD CS

Хост	IP-адрес
CASTELBLACK	192.168.56.22
WINTERFELL	192.168.56.11
MEEREEN	192.168.56.12
KINGSLANDING	192.168.56.10
BRAAVOS	

Что НЕ тестировалось:

- Сторонние системы и продакшн-сервисы
- Социальная инженерия

Тип теста: Grey-box

Сроки: 24.10.2025 — 25.10.2025

3. Methodology (Методология и инструментарий)

Фазы тестирования:

- Разведка — сканирование портов, определение сервисов, LDAP/SMB-разведка
- Первоначальный доступ — загрузка веб-шелла через форму файлов
- Повышение привилегий — GodPotato, mimikatz
- Сбор учётных данных — AS-REP roasting, Kerberoasting, Shadow Credentials
- Боковое перемещение — WinRM, LAPS
- Эскалация до Domain Admin — WriteDACL, ESC1, Golden Ticket
- Закрепление — Scheduled Task от SYSTEM

Инструменты:

Инструмент	Назначение
nmap	Сканирование портов
NetExec	Разведка SMB/LDAP
BloodHound	Анализ ACL в AD
mimikatz	Дамп LSASS и SAM
GodPotato	Повышение привилегий до SYSTEM
Impacket	Kerberoasting, secretsdump, тикеты
john	Взлом хешей
certipy-ad	Атаки на AD CS
evil-winrm	Боковое перемещение
schtasks	Закрепление

4. Detailed Findings (Детальные результаты тестирования)

Vuln 01 — Уязвимость 1: Загрузка ASPX веб-шелла

Критичность: **High**
Хост: CASTELBLACK (192.168.56.22)

Описание:

Форма загрузки файлов на веб-сервере не проверяла тип загружаемого файла. Это позволило загрузить .aspx-скрипт (веб-шелл) и выполнить команды на сервере.

Шаги воспроизведения:

1. Обнаружена форма загрузки: http://192.168.56.22/Default.aspx
2. Загружен файл cmdasp.aspx
3. Получен доступ к /upload/cmdasp.aspx
4. Выполнена команда whoami — получен доступ к серверу

Влияние:

Злоумышленник получает удалённое выполнение кода (RCE) на веб-сервере. Это точка входа во внутреннюю сеть.

Рекомендации:

- Ограничить загрузку файлов по типу (whitelist)
- Добавить серверную валидацию MIME-типов
- Удалить загруженные веб-шеллы
- Внедрить WAF

Vuln 02 — Уязвимость 2: SeImpersonatePrivilege → SYSTEM

Критичность: **Critical**
Хост: CASTELBLACK (192.168.56.22)

Описание:

Пользователь имел право SeImpersonatePrivilege, которое позволяет «притворяться» другим пользователем. Через эксплойт GodPotato получили права SYSTEM — максимальные права на локальной машине.

Шаги воспроизведения:

1. Проверка прав: whoami /priv
2. Обнаружен SeImpersonatePrivilege
3. Загружен и запущен GodPotato.exe
4. Получен NT AUTHORITY\SYSTEM

Влияние:

Полный контроль над хостом. Возможность отключить защиту, извлечь данные из памяти.

Рекомендации:

- Убрать SeImpersonatePrivilege у сервисных аккаунтов
- Внедрить EDR-детект на token impersonation
- Использовать JIT-привилегии

Vuln 03 — Уязвимость 3: Дамп LSASS/SAM через mimikatz

Критичность: **Critical**
Хост: CASTELBLACK (192.168.56.22)

Описание:

После получения SYSTEM запустили mimikatz, который извлёк NT-хеши и пароли из памяти LSASS и базы SAM.

Шаги воспроизведения:

1. Запуск mimikatz с правами SYSTEM
2. Команды: privilege::debug, lsadump::sam, sekurlsa::logonpasswords
3. Получены NT-хеши sql_svc и robb.stark
4. Получен cleartext-пароль sql_svc

Влияние:

Утечка учётных данных → боковое перемещение и дальнейшая компрометация домена.

Рекомендации:

- Включить Windows Defender Credential Guard
- Защита LSASS
- EDR на credential access

Vuln 04 — Уязвимость 4: Kerberoasting

Критичность: **Medium**
Аккаунт: jon.snow

Описание:

Запросили TGS-тикет для сервисного аккаунта и взломали его оффлайн через john.

Шаги воспроизведения:

1. Запуск GetUserSPNs.py -request
2. Получен Kerberos-хеш
3. Взлом через john с словарём

Влияние:

Компрометация сервисного аккаунта. Зависит от привилегий аккаунта.

Рекомендации:

- Сильные случайные пароли для сервисных аккаунтов
- Использовать gMSA (group Managed Service Accounts)
- Мониторить TGS-запросы

Vuln 05 — Уязвимость 5: AS-REP Roasting

Критичность: **Medium**
Аккаунты: brandon.stark, missandei

Описание:

Найдены аккаунты с отключённой Kerberos pre-authentication. Извлекли AS-REP-ответы и взломали оффлайн.

Шаги воспроизведения:

1. Перечисление пользователей
2. Запуск as-rep-roast
3. Получены хеши
4. Взлом через john

Влияние:

Кража учётных данных, боковое перемещение.

Рекомендации:

- Включить Kerberos pre-authentication
- Удалить legacy-аккаунты
- Мониторить AS-REP-запросы

Vuln 06 — Уязвимость 6: WriteDACL на Domain Admins

Критичность: **Critical**
Хост: WINTERFELL (192.168.56.11)

Описание:

BloodHound показал, что пользователь robb.stark имеет WriteDACL на группу Domain Admins. Это позволяет изменить ACL группы и добавить себя в неё — то есть получить Domain Admin.

Шаги воспроизведения:

1. BloodHound-анализ выявил WriteDACL
2. Команды не выполнялись (задокументирован примитив)

Влияние:

Полная эскалация до Domain Admin.

Рекомендации:

- Убрать лишние DACL с критичных групп
- Алерты на изменения ACL
- Автоматический аудит прав

Vuln 07 — Уязвимость 7: ESC1 через AD CS

Критичность: **Critical**
Хост: MEEREEN (192.168.56.12)

Описание:

Уязвимый шаблон сертификата (ESC1) позволял низкопривилегированному пользователю запросить сертификат от имени другого пользователя.

Шаги воспроизведения:

1. certipy-ad find -vulnerable
2. Найден ESC1 на шаблоне ESSOS-CA
3. Запрос PFX для goadmin
4. Получен NT-хеш goadmin
5. Вход через WinRM

Влияние:

Эскалация привилегий и боковое перемещение, потенциальный захват домена.

Рекомендации:

- Ограничить enrollment-права
- Требовать approval для auth-шаблонов
- Регулярный аудит шаблонов

Vuln 08 — Уязвимость 8: Golden Ticket (подделка Kerberos-тикета)

Критичность: **Critical**
Хост: KINGSLANDING (192.168.56.10)

Описание:

Извлекли trust key домена и через ticketer.py подделали Kerberos-тикет для вымышленного Enterprise Admin (gogoadmin). С этим тикетом получили доступ к контроллеру домена.

Шаги воспроизведения:

1. secretsdump — извлечён trust key
2. ticketer.py — подделан тикет gogoadmin

3. Запрос TGS для cifs/kingslanding
4. secretsdump — извлечён NT-хеш cersei.lannister
5. Вход через WinRM

Влияние:

Полная компрометация домена. Доступ ко всем ресурсам.

Рекомендации:

- Сменить пароль krbtgt дважды
- Ограничить inter-forest admin
- Мониторинг аномальных тикетов

Vuln 09 — Уязвимость 9: Закрепление через Scheduled Task

Критичность: **High**
Хост: KINGSLANDING (192.168.56.10)

Описание:

Создали scheduled task, которая запускала reverse shell каждую минуту от имени SYSTEM. Это обеспечило постоянный доступ.

Шаги воспроизведения:

1. Скомпилирован FileProcessor.exe (reverse shell)
2. Загружен через WinRM
3. Создана задача через schtasks
4. Получен shell от NT AUTHORITY\SYSTEM

Влияние:

Постоянный SYSTEM-бэкдор.

Рекомендации:

- Удалить задачу и экзешник
- Endpoint protection и allowlisting
- Мониторинг создания задач

Vuln 10 — Уязвимость 10: WinRM Lateral Movement

Критичность: **Medium**
Хосты: BRAAVOS, MEEREEN, KINGSLANDING

Описание:

Использовали собранные учётные данные для входа на другие хосты по WinRM.

Шаги воспроизведения:

1. Собраны NT-хеши

2. evil-winrm — вход на хосты
3. Выполнение команд

Влияние:

Боковое перемещение, риск компрометации домена.

Рекомендации:

- Ограничить WinRM через firewall/GPO
- MFA для удалённого доступа
- Аудит WinRM-подключений

5. Conclusion & Strategic Roadmap (Заключение и выводы)

В ходе работы изучена структура отчёта по пентесту и оформлен учебный пример на основе публичного отчёта GOAD Red Team Engagement.

Что было сделано:

- Изучена структура профессионального отчёта
- Разобраны 10 ключевых уязвимостей Active Directory
- Оформлены находки по единому шаблону
- Составлены рекомендации по устранению

Ключевые выводы:

- Атака — это цепочка уязвимостей, а не одна дыра
- Учётные данные — главная валюта атакующего
- Active Directory требует постоянного аудита прав
- Защита должна быть многослойной

Главные рекомендации:

- Убрать уязвимую форму загрузки файлов
- Ограничить SeImpersonatePrivilege
- Исправить шаблоны AD CS
- Убрать WriteDACL с критичных групп
- Сменить krbtgt дважды
- Внедрить мониторинг Kerberos-аномалий

6. Appendices & References (Приложения и источники)

Источник: GOAD Red Team Engagement Report (публичный отчёт)

Использованные источники:

- MITRE ATT&CK Framework
- OWASP Testing Guide
- Документация Microsoft по AD Security

Конец отчёта.